

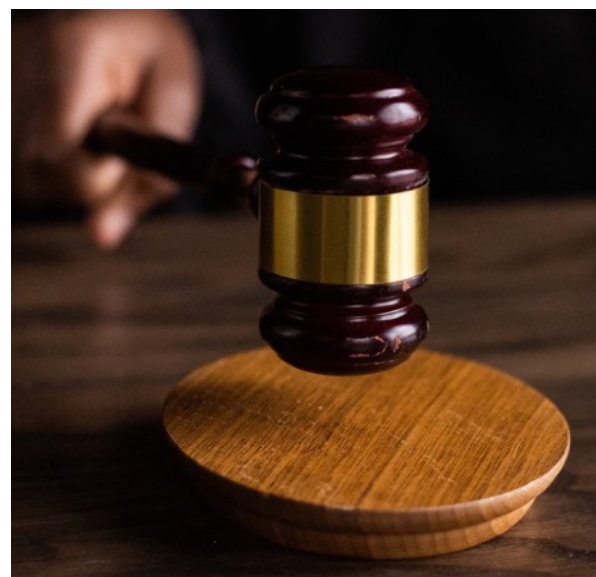
Foundations of Cyber Security

COMSM 0118 - Legal and Ethical Aspects

What is law?

“... a binding custom or practice of a community: a rule of conduct or action prescribed or formally recognised as binding or enforced by a controlling authority.”

“... a system of rules that a society or government develops in order to deal with crime, business agreements, and social relationships.”



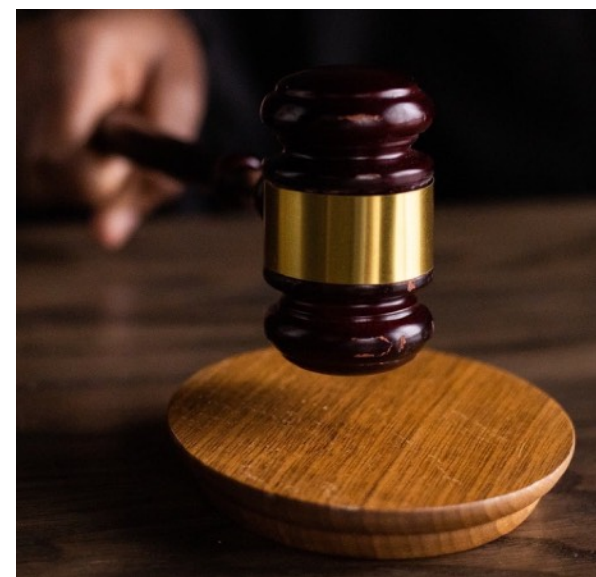
What is law?

“... a binding custom or practice of a community: a rule of conduct or action prescribed or formally recognised as binding or enforced by a controlling authority.”

“... a system of rules that a society or government develops in order to deal with crime, business agreements, and social relationships.”

Purpose of the law...

- Addressing the responsibility of persons and the disposition of property.
- Protect people/society
- Regulates the human conduct



What is law?

“... a binding custom or practice of a community: a rule of conduct or action prescribed or formally recognised as binding or enforced by a controlling authority.”

“... a system of rules that a society or government develops in order to deal with crime, business agreements, and social relationships.”

Purpose of the law...

- Addressing the responsibility of persons and the disposition of property.
- Protect people/society
- Regulates the human conduct

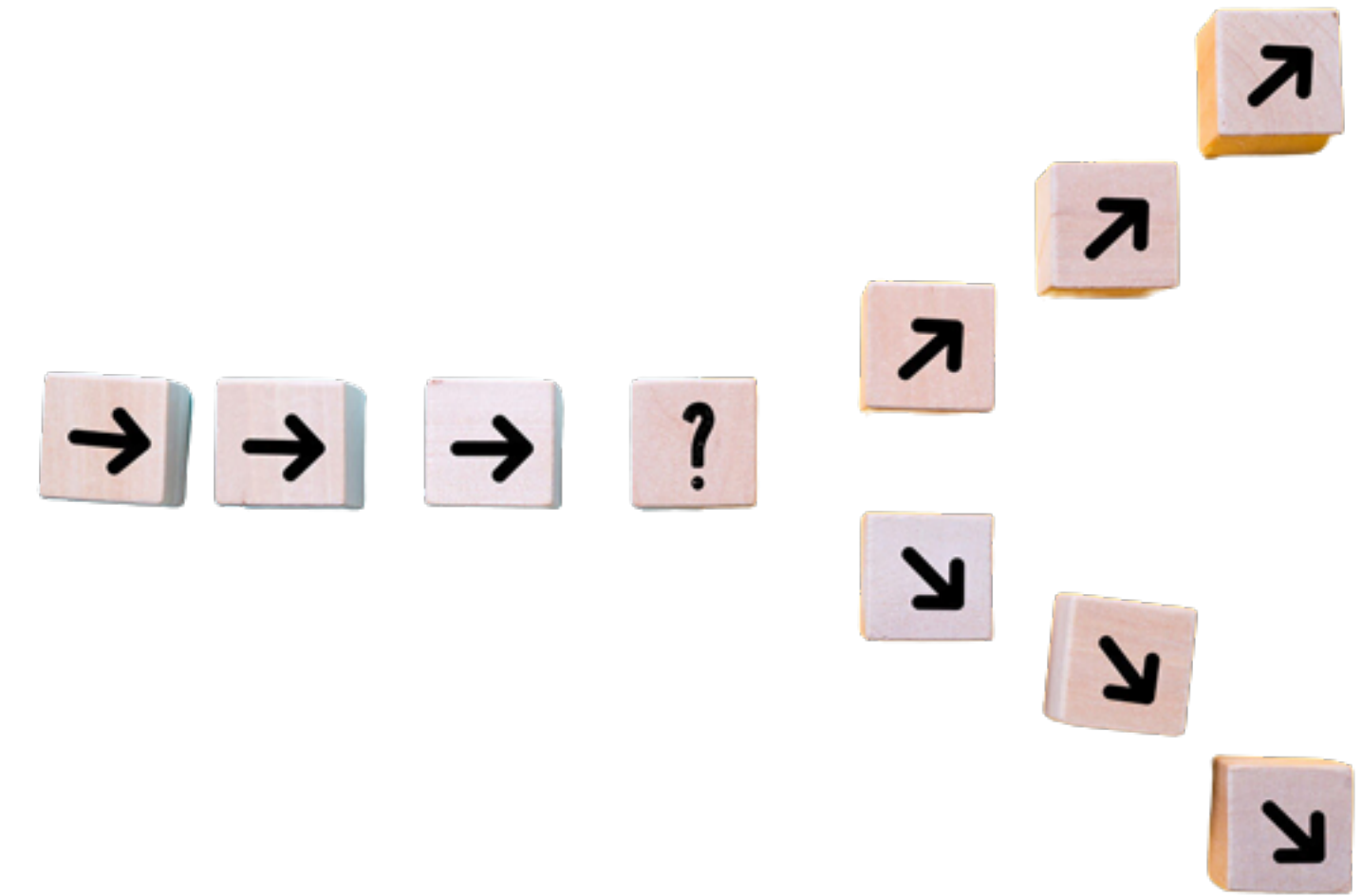
Sources of the law...

- Custom
- Actions of representatives of people
- Decisions of the court (Precedent)
- Actions of administrative agency
- Agreements between people



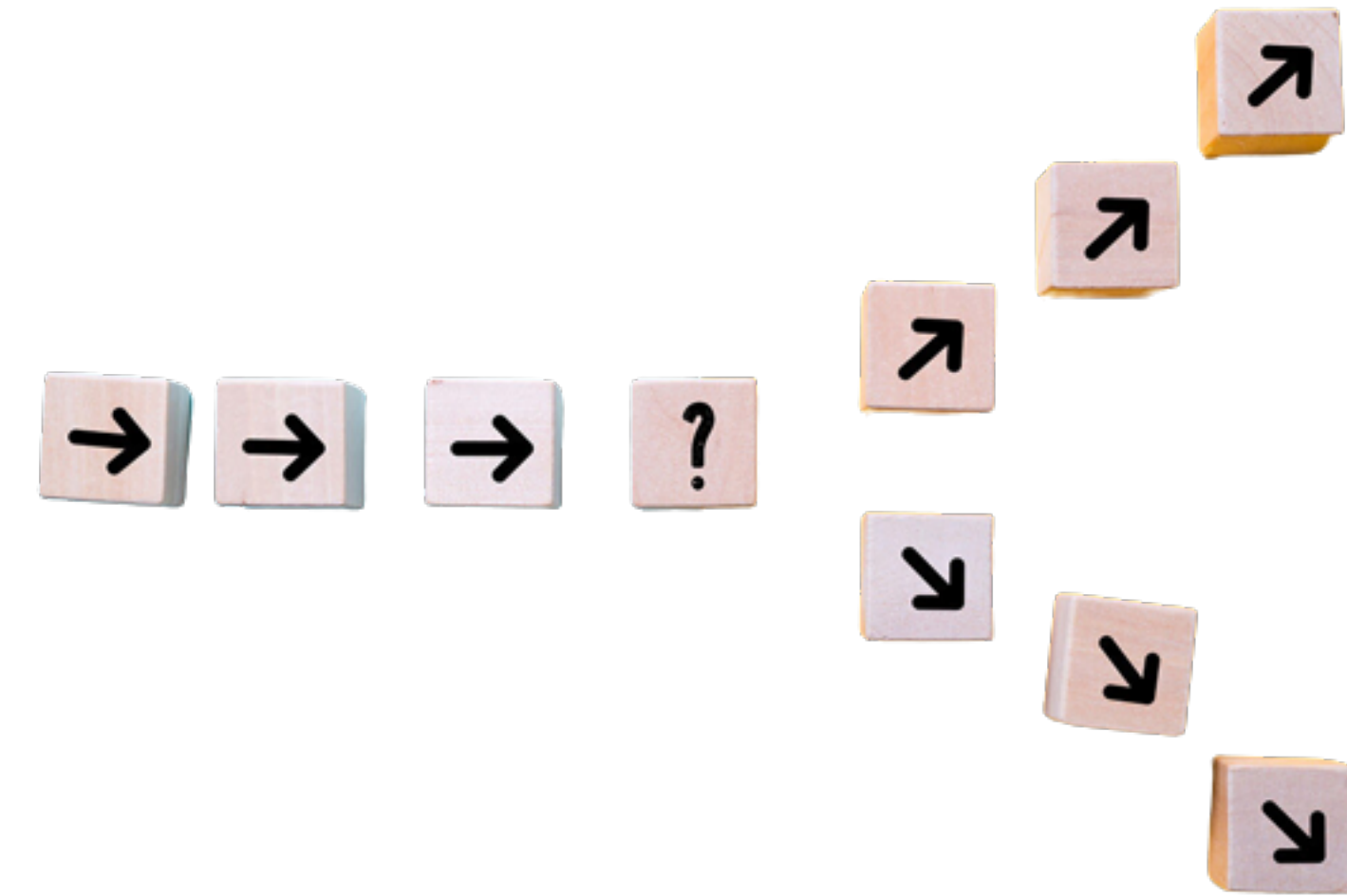
What is law?

- *is dynamic and influences society*
- *changes all the times (e.g., ruling)*
- *People influence the law*
- *New ideas (technology)*
- *can interact in with other laws in complex ways*
- *Law is territorial; a reflection of the society.*



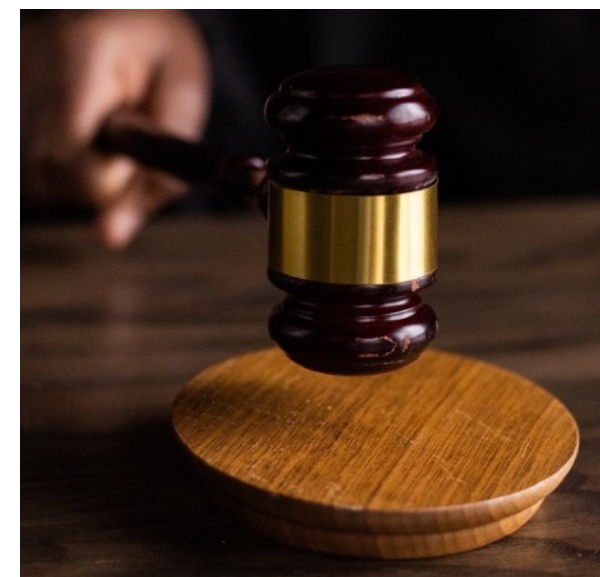
What is law?

- *is dynamic and influences society*
- *changes all the times (e.g., ruling)*
- *People influence the law*
- *New ideas (technology)*
- *can interact in with other laws in complex ways*
- *Law is territorial; a reflection of the society.*



Uncertainty...

- *Method of interpretation are different **
- *Differing sources **



* Robert Carolina - CyBOK: Law and Regulations

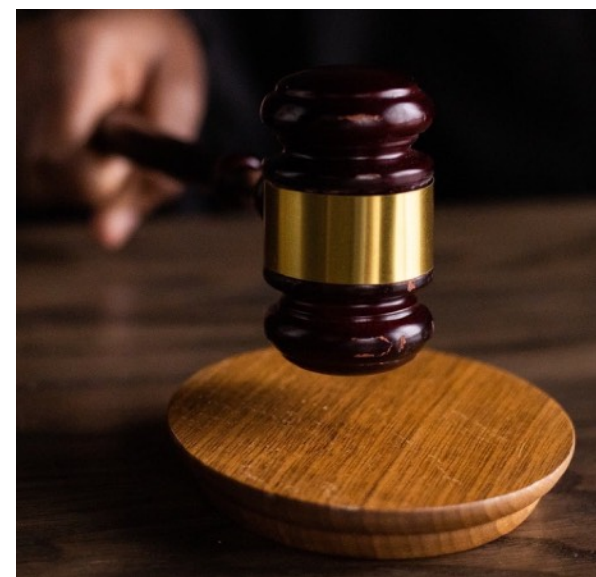
Law and technology

Cyberspace is unbounded, is not a territory.

The internet get us to discuss international laws.

Because sometimes we need to resolve issues of two entities arguing between two countries.

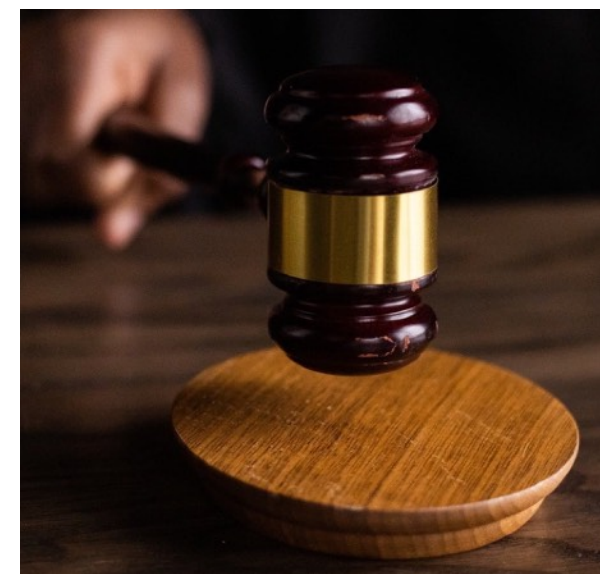
In case of two people arguing, each country will apply their own laws to protect their own people.



Law and technology

Examples...

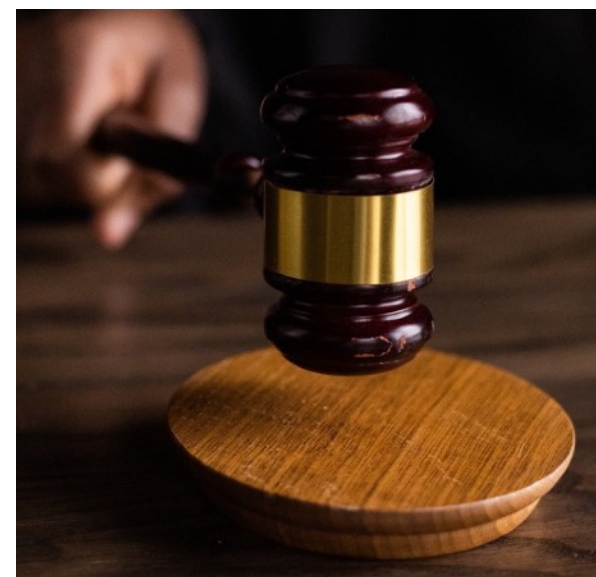
- General Data Protection Regulation (GDPR)
 - Consumer Privacy Protection Act (CPPA)
 - Children's Online Privacy Protection Act (COPRA)
 - California Consumer Privacy Act (CCPA)
 - Computer Fraud And Abuse Act (CFAA)
 - Computer Misuse Act (CMA)
 - Health insurance Portability and Accountability Act (HIPPA)
 - Online Safety bill
-
- Intellectual Property (IP) laws
 - Copyright laws
 - Contract laws
 - Tort laws



Law and Security Practitioners

Potential risky activities...

- Vulnerability research
- Penetration testing
- Reverse engineering
- Sensitive information
- ...



Law and Security Practitioners

Potential risky activities...

- Vulnerability research
 - Penetration testing
 - Reverse engineering
 - Sensitive information
 - ...
-
- Accessing devices without owner's permission
 - Copying, modifying, or running software that belongs to other people (copyright laws)
 - Circumventing measures designed to prevent or restrict access to software
 - Transferring non-published information, code, or equipment related to cryptography to a foreign destination, outside the ordinary course of research.
 - disclosing information about software or a system design that a company keeps secret from a competitor



Law: Computer Misuse Act (CMA)

History...

“The Appeal Court in 1985 indicated that if a person sent a message from London to divert funds from New York to his accounts in Geneva, the theft would not have taken place in London and so English courts would not have had jurisdiction to try the offender.” [1]

Enacted in 1990

*“After two individuals obtained **without knowledge** the username and password of an engineer who worked for a telecom company. They managed to get **access** to Prince Philip’s emails. They were arrested, convicted under the Forgery and Counterfeiting Act (1981). Later appealed because they stated that they didn’t do it for financial gain but to demonstrate that the system could be **hacked**. Convictions were overturned.”*

Computer Misuse Act 1990 “created to deal with those who use or access computers for malicious purposes” or hacking

[1] <https://www.lawteacher.net/free-law-essays/criminal-law/computer-misuse-act.php?vref=1>

Law: Computer Misuse Act (CMA)

Focuses on the following sections...

- Unauthorised access to computer material.
- Unauthorised access with intent to commit or facilitate commission of further offences.
- Unauthorised acts with intent to impair, or with recklessness as to impairing, operation of computer.
- Unauthorised acts causing, or creating risk of, serious damage.
- Making, supplying or obtaining articles for use in offence under section 1, 3 or 3ZA.

*“It criminalises several acts, including **accessing data without authorisation** (i.e., hacking), **installing malware** (e.g., computer viruses, spyware, or ransomware) on a person's computer, and **producing materials** for committing mentioned offences.”*

Law: Computer Misuse Act (CMA)

What is a “Computer?”

“ Any device or group of interconnected or related devices, one or more of which pursuant to a program, performs automatic processing of data” *Council of Europe Cybercrime Convention 2001*

“... a device for storing, processing and retrieving information.” *Court Cases: DPP v McKeown, DPP v Jones*

Desktop computers, laptops, IoT devices, mobile devices, and servers.



Law: Computer Misuse Act (CMA)

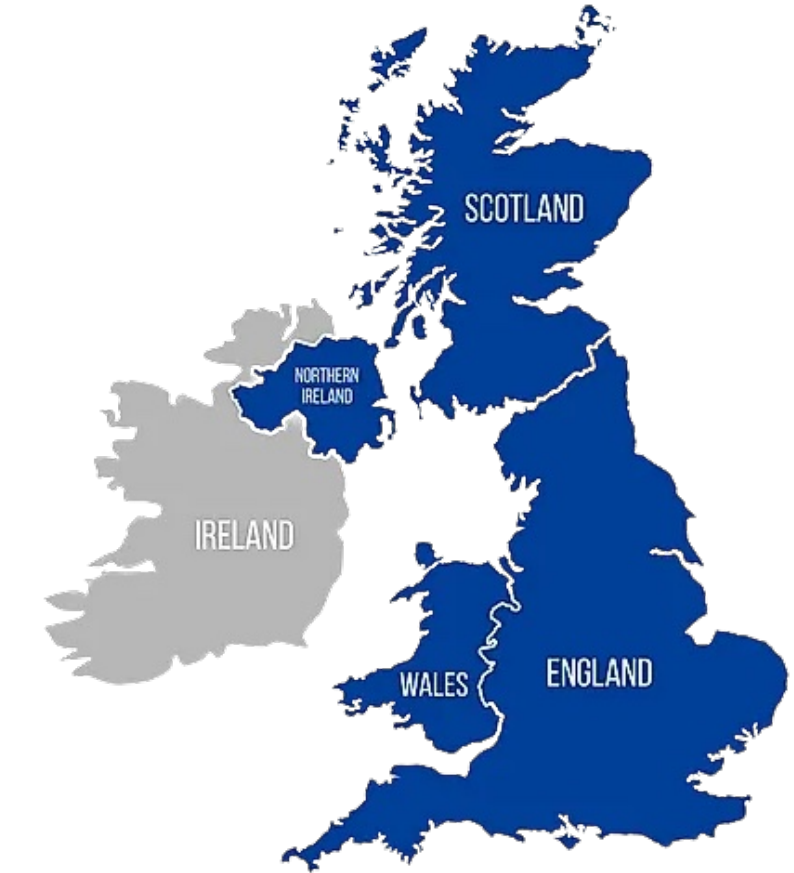
Jurisdiction (territorial scope)

... requires proof of at least one ‘**significant link**’ with the ‘**home country**’

Home country: ***England, Wales, Scotland and North Ireland ****

Section 1, 3, 3ZA

A significant link could include:



- The accused is in the home country at the time of the offence
- The target of the CMA offence is in the home country
- The technological activity which has facilitated the offending may have passed through a server based in the home country

Section 5, in relation to an offence under Section 3ZA, significant link

- That the accused was in the home country concerned at the time when s/he committed the unauthorised act (or caused it to be done);
- That the unauthorised act was done in relation to a computer in the home country concerned;
- That the unauthorised act caused, or created a significant risk of, serious damage of a material kind (within the meaning of that section) in the home country concerned.

<https://www.cps.gov.uk/legal-guidance/computer-misuse-act>

* <https://www.legislation.gov.uk/ukpga/1990/18/crossheading/jurisdiction>

Law: Computer Misuse Act (CMA)

Examples...

DPP v Bignell [1998]

Two police officers (Mr and Mrs Bignell), who were authorised to request information from the police national computer (PNC) for policing purposes only, requested a police computer operator to obtain information from the PNC which, unbeknown to the operator, was for their own personal use. [1]

R v Vallor [2003]

A 22-old Welsh Web designer who pleaded guilty to creating and distributing three mass mailer viruses was sentenced to two years imprisonment at Southwark Crown Court this afternoon. [2]

R v Mudd [2018] 1 Cr App R (S) 33 (7)

The offender, who was aged between 16 and 18 over the course of the offending, admitted offences under sections 1 and 3, and a further offence of concealing criminal property. He had devised a distributed denial of service program which he used on some occasions himself and on other occasions supplied the program for payment for others to use. In total, 1.7 million DDoS attacks were carried out directed at well over half a million individual IP addresses or domain names. [3]

[1] DPP v Bignell [1998] 1 Cr. App. R. 1

[2] https://www.theregister.com/2003/01/21/welsh_virus_writer_vallor_jailed/

[3] <https://www.cps.gov.uk/legal-guidance/computer-misuse-act>

Law: Computer Misuse Act (CMA)

Critics...

- Was enacted before cyber security existed
- It criminalises security researchers
- It fails to recognise the value of "ethical" or "white hat" hacking
- It hard to prove “intent”
- No scope for hacking-back
- Web-Scraping deemed lawful

Law: Computer Misuse Act (CMA)

Critics...



Security researcher [@robbykedotcom](#) recently discovered and responsibly disclosed security vulnerabilities to [@AppertaUK](#) about sensitive information stored on their publicly accessible repositories. He now faces legal retaliation. Let's help him.



gofundme.com
Defend Rob's Responsible Disclosure, organized by Rob Dyke
TL/DR: I made a responsible security disclosure to Apperta, an NHS tech org, that had ... Rob Dyke needs your support for Defend Rob's Responsible ...

Dyke found a public repo containing the source code for an insecure online portal and its database containing usernames, hashed passwords, email addresses, and API keys. [1]

Laws and regulations

Other issues...

- Restrictions on exporting security technologies
- Strong cryptographic products (e.g., Export Admin Regulations)
- Matters/Issues classified as secret by a state

Further Reading

- **CyBOK Law and regulations: https://www.cybok.org/media/downloads/Law_Regulation_v1.0.2.pdf**
- **J. Goldsmith and T. Wu, Who Controls the Internet? Illusions of a Borderless World. New York, NY: Oxford University Press, 2006.**
- **S. K Hayes and J. Niehaus, Defensive tactics for Today's Law enforcement, Taylor & Francis Group, 2017**
- **Computer Misuse Act: <https://www.cps.gov.uk/legal-guidance/computer-misuse-act>**

VULNERABILITY RESEARCH

VULNERABILITY RESEARCH

“Vulnerabilities are undesirable in all facets of life.”

The word “**vulnerable**” derives from the Latin *vulnus*, meaning “wound.” [1]

“... a vulnerability is a behaviour or set of conditions present in a system, product, component, or service that “violates an implicit or explicit security policy.”” ISO/IEC 29147:2018 – Information Technology - Vulnerability Disclosure

[1] <https://www.etymonline.com/word/vulnerable>

VULNERABILITY RESEARCH

Vulnerability

“... is a behaviour or set of conditions present in a system, product, component, or service that “violates an implicit or explicit security policy.”” ISO/IEC 29147:2018 – Information Technology - Vulnerability Disclosure

Security threat

“... a malicious act that can exploit a vulnerability..”

Security risk

“... what may happen when a security threat exploits a vulnerability in a system. Potential damage, loss, destruction of an asset. ”



VULNERABILITY RESEARCH

Systems are not always perfect, they sometimes contain vulnerabilities (weakness)

Attackers exploit vulnerabilities to compromise operation and security properties of a system.

- **Confidentiality**
- **Integrity**
- **Availability**
- **Operation**
- **Authentication**
- **Authorization**
- **Nonrepudiation**



VULNERABILITY RESEARCH

Examples of vulnerabilities

- **Misconfigurations**
- **Unsecured APIs**
- **Outdated or unpatched software**
- **Zero-day vulnerabilities**
- **Weak or stolen user credentials**
- **Access control**
- **Unchecked user input**



VULNERABILITY RESEARCH

To improve security one may need to invest in vulnerability research

Vulnerability research

... an act of identifying security vulnerabilities in hardware and software devices, driven by the desire to prevent harms and engage in a responsible disclosure upon discovery.

Difference between “Research and Computer crime”



VULNERABILITY RESEARCH

To improve security one may need to invest in vulnerability research

Vulnerability research

... an act of identifying security vulnerabilities in hardware and software devices, driven by the desire to prevent harms and engage in a responsible disclosure upon discovery.

Difference between “Research and Computer crime”

Vulnerability Detection methods

- **Penetration testing**
- **Vulnerability scanning**
- **Reverse engineering**
-



VULNERABILITY RESEARCH

Methods of testing

Black box testing (e.g., Fuzzing)

- internal structure of code or program not known.
- usually done based on the requirements



VULNERABILITY RESEARCH

Methods of testing

Black box testing (e.g., Fuzzing)

- internal structure of code or program not known.
- usually done based on the requirements

White box testing (e.g., Unit testing)

- internal are known to the tester. (e.g., developers)
- detailed design of the system



VULNERABILITY RESEARCH

Methods of testing

Black box testing (e.g., Fuzzing)

- internal structure of code or program not known.
- usually done based on the requirements

White box testing (e.g., Unit testing)

- internal are known to the tester. (e.g., developers)
- detailed design of the system

Grey box testing (e.g., Regression testing)

- limited info is shared with the tester



VULNERABILITY RESEARCH

Why does it matter?

- Escalating number of threats
- Desire to eliminate vulnerabilities
- Vulnerable products erode commercial trust
- Social responsibility - Prevent harm, close the information gap
- To develop interventions or mitigate harm

Principle

- Prevention of harm



VULNERABILITY RESEARCH

Best practices include

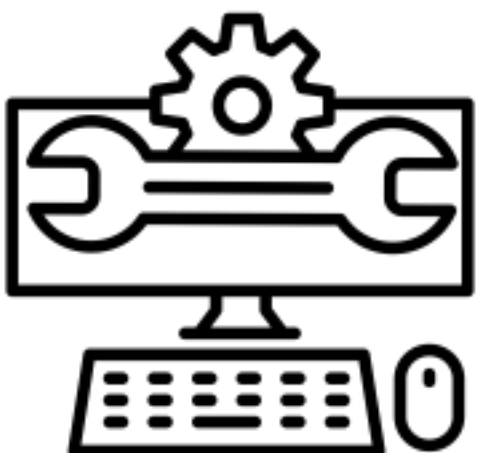
- **Disclose intent and research**
- **Seeking legal counsel prior to starting research**
- **Be proactive about data protection**
- **Contribute to existing knowledge in the field**
- **Train others**
- **Do not use pirated software or tools**



VULNERABILITY RESEARCH

Reverse Engineering

“The process of taking a piece of software or hardware and analysing its functions and information flow so that its functionality and behaviour can be understood.”



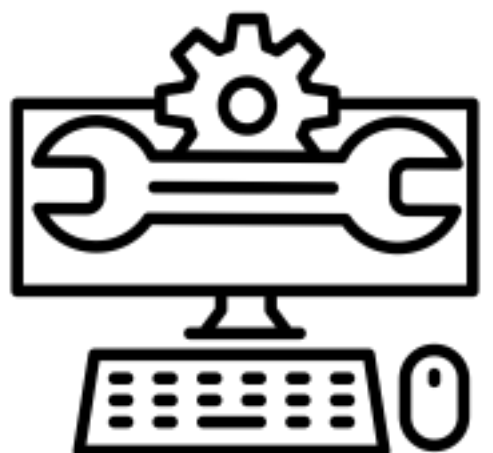
VULNERABILITY RESEARCH

Reverse Engineering

“The process of taking a piece of software or hardware and analysing its functions and information flow so that its functionality and behaviour can be understood.”

Other articulations

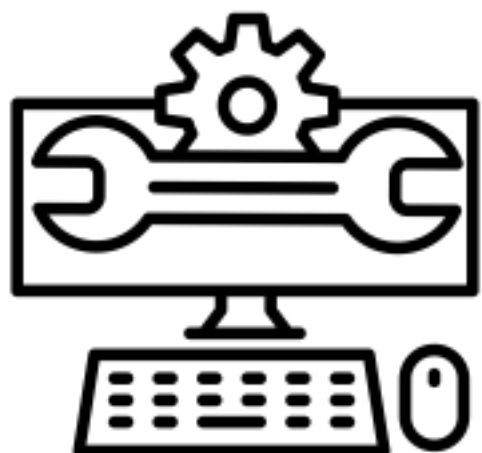
- *Deconstructing a device or piece of hardware or software*
- *Decompiling*
- *Disassembling or executable files and libraries*
- *Analysis of the system data*



VULNERABILITY RESEARCH

Why reverse engineering?

- *Protecting a system may require an understanding of how the system actually work.*
- *It helps when trying to defend against malware and viruses*
- *assessing the difficulty of restoring essential software algorithms*
- *device archaeology (developers leaving/ missing documentation)*



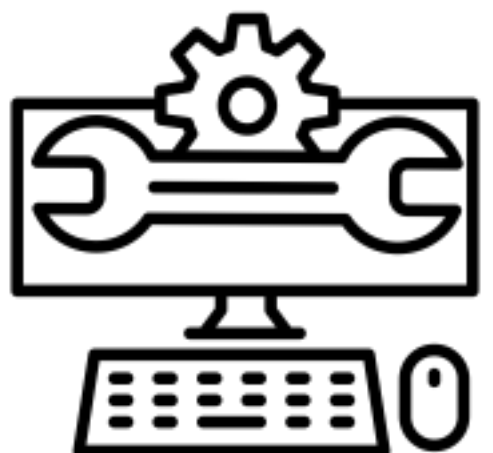
VULNERABILITY RESEARCH

Why reverse engineering?

- *Protecting a system may require an understanding of how the system actually work.*
- *It helps when trying to defend against malware and viruses*
- *assessing the difficulty of restoring essential software algorithms*
- *device archaeology (developers leaving/ missing documentation)*

Reverse engineering tools

- System monitoring tools
- Disassembling tools
- Debug tools
- Decompilers
- Hex editors
- Unpackers
- File analysing tools



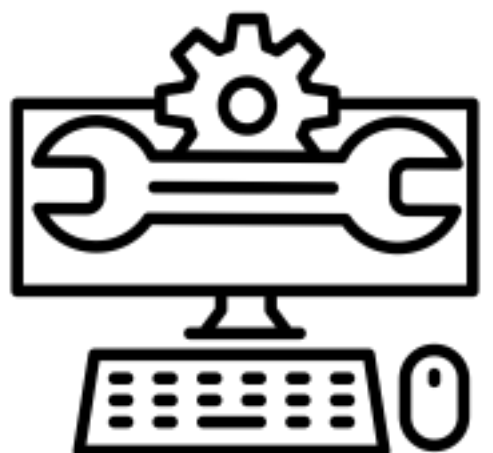
VULNERABILITY RESEARCH

Reverse Engineering and Law

While it was traditionally accepted as a normal behaviour it is considered illegal in some jurisdictions.

Laws that reverse engineering may infringe

- Copyright law
- Computer Misuse Act
- Contract laws - agreed terms
- Trade secret law



VULNERABILITY RESEARCH

Vulnerability Disclosure

“...techniques and policies for vendors to receive vulnerability reports and publish remediation information.” ISO/IEC 29147:2018 – Information Technology - Vulnerability Disclosure

Vulnerability disclosures are ***critical for supporting and maintaining products or services*** that are exposed to ***threats***. They are important and should be ***taken seriously***.



VULNERABILITY RESEARCH

Vulnerability Disclosure

“...techniques and policies for vendors to receive vulnerability reports and publish remediation information.” ISO/IEC 29147:2018 – Information Technology - Vulnerability Disclosure

Vulnerability disclosures are **critical for supporting and maintaining products or services** that are exposed to **threats**. They are important and should be **taken seriously**.

Challenges...

- Lack of consensus on the process of “responsible” disclosure
- The vendors may not be aware of the vulnerability ins some full disclosure cases
- State security agencies
- The relationship between discoverers and vendors remains complex. (Bug bounties)



VULNERABILITY RESEARCH

Vulnerability Disclosure

NIST SP 800-216: Recommendations for Federal Vulnerability Disclosure Guidelines

ISO/IEC 29147:2018 Information technology - Security techniques - Vulnerability disclosure



VULNERABILITY RESEARCH

Vulnerability Disclosure



NVD



VULNERABILITY RESEARCH

Methods of Vulnerability Disclosure

Non-Disclosure

- The vulnerability is discovered but not disclosed to the vendor



VULNERABILITY RESEARCH

Methods of Vulnerability Disclosure

Non-Disclosure

- The vulnerability is discovered but not disclosed to the vendor



Private Disclosure

- The vulnerability is reported privately to the organisation or vendor.
- The organisation may choose to publish the details of the vulnerabilities
- Common type around bug bounty programs
- The details of the disclosure may never be made public.



VULNERABILITY RESEARCH

Methods of Vulnerability Disclosure

Non-Disclosure

- The vulnerability is discovered but not disclosed to the vendor



Private Disclosure

- The vulnerability is reported privately to the organisation or vendor.
- The organisation may choose to publish the details of the vulnerabilities
- Common type around bug bounty programs
- The details of the disclosure may never be made public.



Full Disclosure

- The full details of the vulnerability are made public as soon as they are identified.
- Full details made available to everyone (including attackers), often before a patch is available.
- Commonly used when the vendor is not responsive (i.e., increase pressure to develop and publish a fix).
- Controversial - Some think it is irresponsible



Schneier writes:

'Public scrutiny is the only reliable way to improve security, while secrecy only makes us less secure.'

VULNERABILITY RESEARCH

Methods of Vulnerability Disclosure

Non-Disclosure

- The vulnerability is discovered but not disclosed to the vendor



Private Disclosure

- The vulnerability is reported privately to the organisation or vendor.
- The organisation may choose to publish the details of the vulnerabilities
- Common type around bug bounty programs
- The details of the disclosure may never be made public.



Full Disclosure

- The full details of the vulnerability are made public as soon as they are identified.
- Full details made available to everyone (including attackers), often before a patch is available.
- Commonly used when the vendor is not responsive (i.e., increase pressure to develop and publish a fix).
- Controversial - Some think it is irresponsible



Schneier writes:

'Public scrutiny is the only reliable way to improve security, while secrecy only makes us less secure.'

Responsible or Coordinated Disclosure

- The middle ground
- Researcher and vendor work together
- The initial report on the vulnerability is made privately to the organisation or vendor
- The full details are published once a patch has been made available



https://cheatsheetseries.owasp.org/cheatsheets/Vulnerability_Disclosure_Cheat_Sheet.html

VULNERABILITY RESEARCH

Vulnerability Disclosure Case study: Heartbleed (CVE-2014-0160)

- OpenSSL cryptography library bug
- Date discovered: 1 April 2014
- Existed since 2012
- Take advantage of the heartbeat process. (Victim bleeds sensitive info to the attacker)
- Exposes contents of the memory buffer



VULNERABILITY RESEARCH

Vulnerability Disclosure Case study: Heartbleed (CVE-2014-0160)

- OpenSSL cryptography library bug
- Date discovered: 1 April 2014
- Existed since 2012
- Take advantage of the heartbeat process. (Victim bleeds sensitive info to the attacker)
- Exposes contents of the memory buffer



VULNERABILITY RESEARCH

Vulnerability Disclosure Case study: Heartbleed (CVE-2014-0160)

- OpenSSL cryptography library bug
- Date discovered: 1 April 2014
- Existed since 2012
- Take advantage of the heartbeat process. (Victim bleeds sensitive info to the attacker)
- Exposes contents of the memory buffer



VULNERABILITY RESEARCH

Vulnerability Disclosure Case study: Heartbleed (CVE-2014-0160)

- OpenSSL cryptography library bug
- Date discovered: 1 April 2014
- Existed since 2012
- Take advantage of the heartbeat process. (Victim bleeds sensitive info to the attacker)
- Exposes contents of the memory buffer



VULNERABILITY RESEARCH

Vulnerability Disclosure Case study: Heartbleed (CVE-2014-0160)

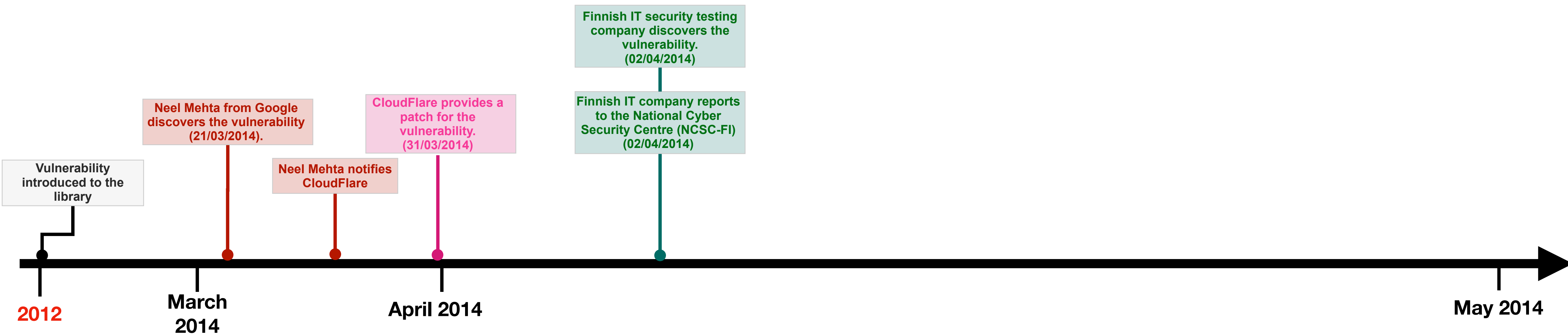
- OpenSSL cryptography library bug
- Date discovered: 1 April 2014
- Existed since 2012
- Take advantage of the heartbeat process. (Victim bleeds sensitive info to the attacker)
- Exposes contents of the memory buffer



VULNERABILITY RESEARCH

Vulnerability Disclosure Case study: Heartbleed (CVE-2014-0160)

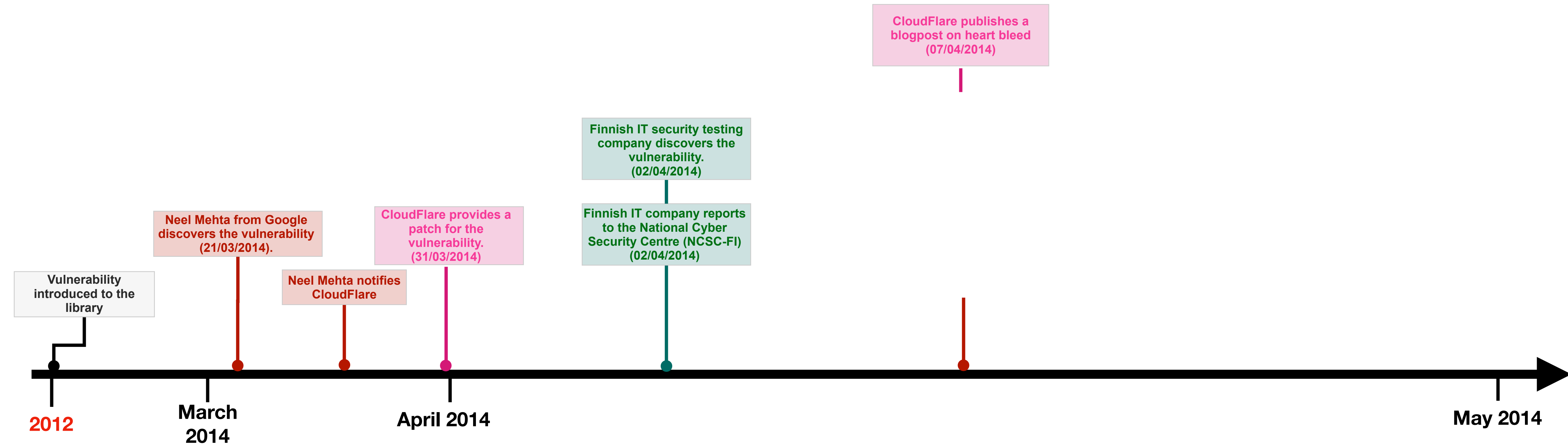
- OpenSSL cryptography library bug
- Date discovered: 1 April 2014
- Existed since 2012
- Take advantage of the heartbeat process. (Victim bleeds sensitive info to the attacker)
- Exposes contents of the memory buffer



VULNERABILITY RESEARCH

Vulnerability Disclosure Case study: Heartbleed (CVE-2014-0160)

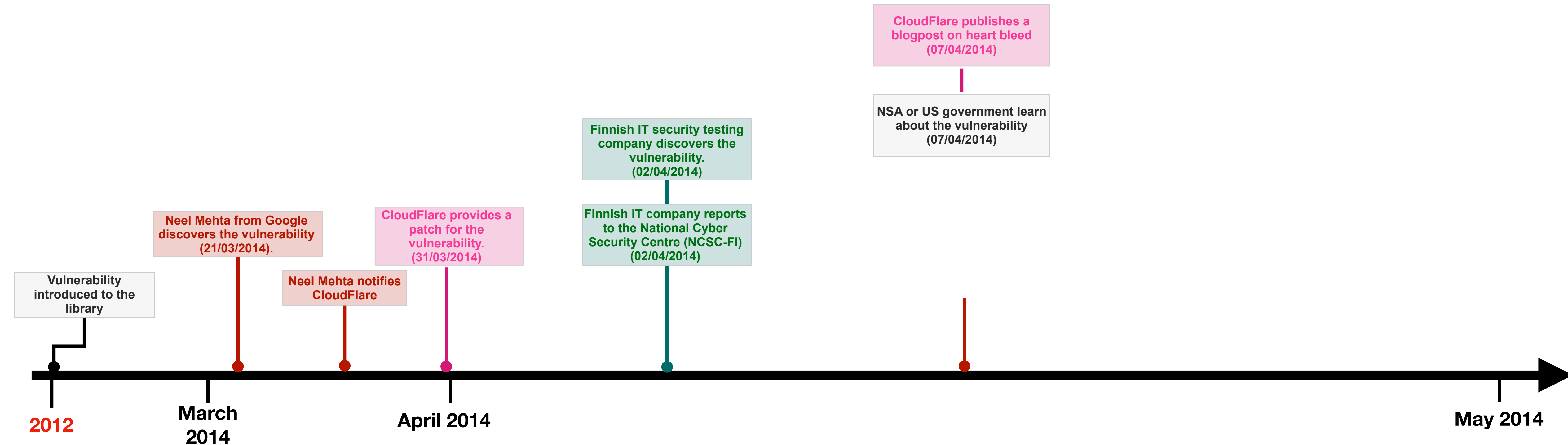
- OpenSSL cryptography library bug
- Date discovered: 1 April 2014
- Existed since 2012
- Take advantage of the heartbeat process. (Victim bleeds sensitive info to the attacker)
- Exposes contents of the memory buffer



VULNERABILITY RESEARCH

Vulnerability Disclosure Case study: Heartbleed (CVE-2014-0160)

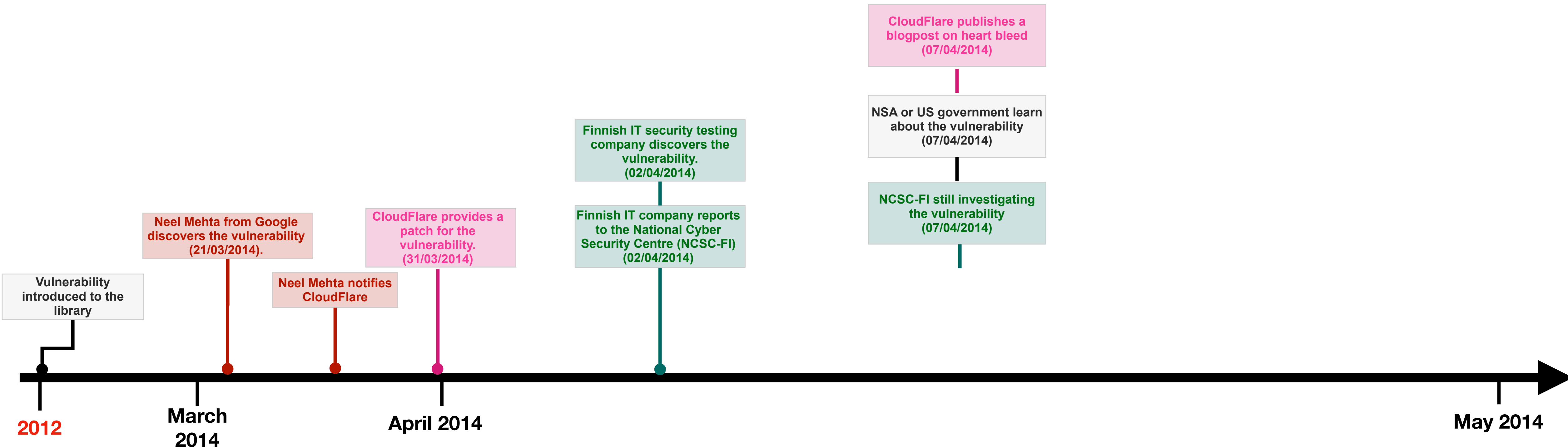
- OpenSSL cryptography library bug
- Date discovered: 1 April 2014
- Existed since 2012
- Take advantage of the heartbeat process. (Victim bleeds sensitive info to the attacker)
- Exposes contents of the memory buffer



VULNERABILITY RESEARCH

Vulnerability Disclosure Case study: Heartbleed (CVE-2014-0160)

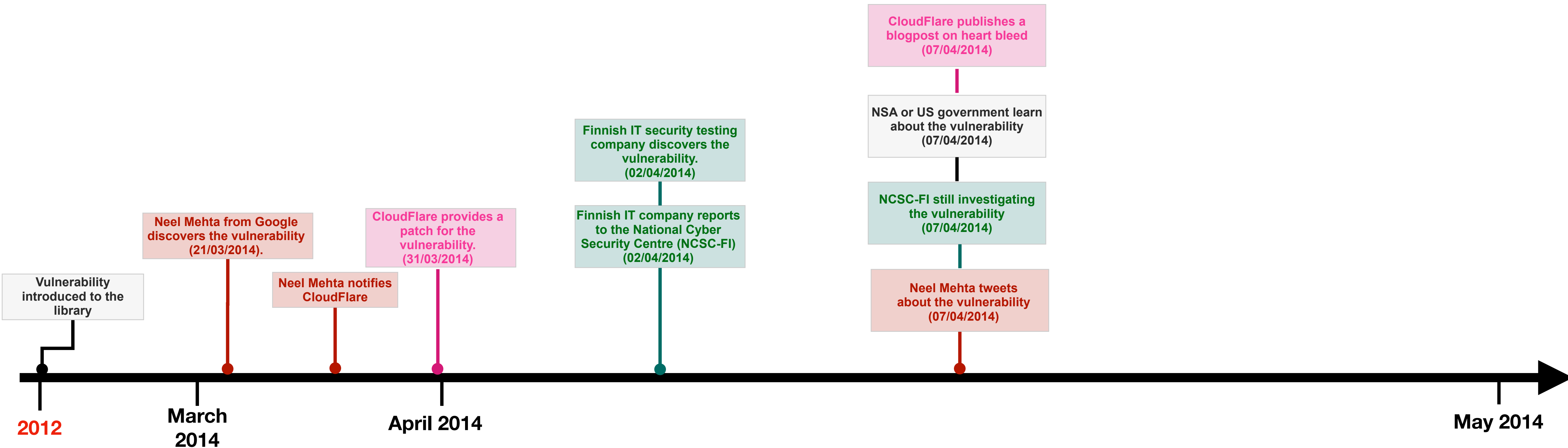
- OpenSSL cryptography library bug
- Date discovered: 1 April 2014
- Existed since 2012
- Take advantage of the heartbeat process. (Victim bleeds sensitive info to the attacker)
- Exposes contents of the memory buffer



VULNERABILITY RESEARCH

Vulnerability Disclosure Case study: Heartbleed (CVE-2014-0160)

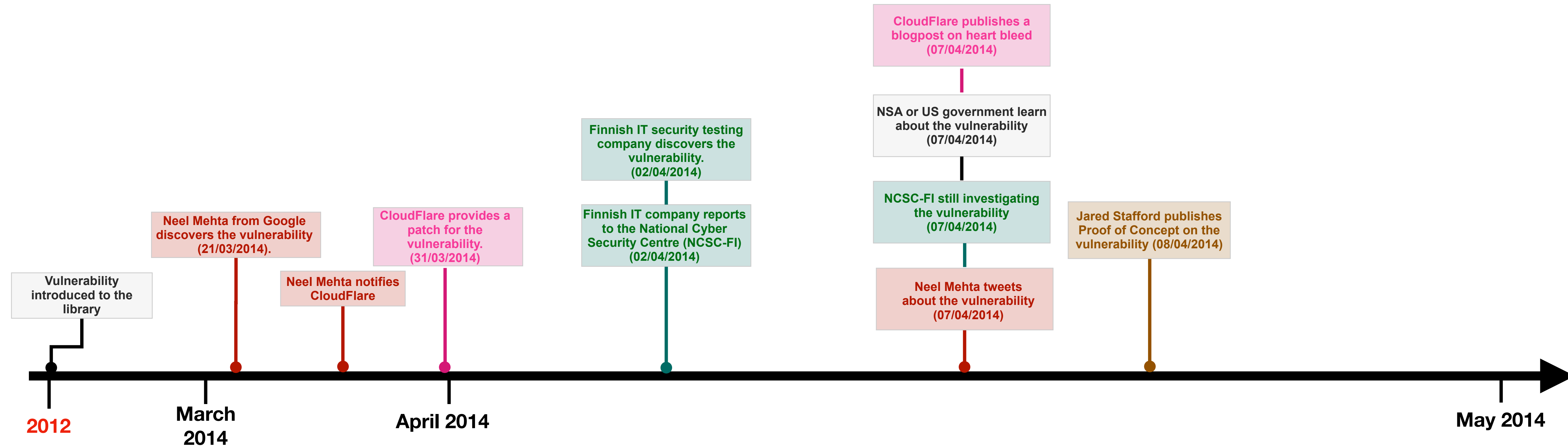
- OpenSSL cryptography library bug
- Date discovered: 1 April 2014
- Existed since 2012
- Take advantage of the heartbeat process. (Victim bleeds sensitive info to the attacker)
- Exposes contents of the memory buffer



VULNERABILITY RESEARCH

Vulnerability Disclosure Case study: Heartbleed (CVE-2014-0160)

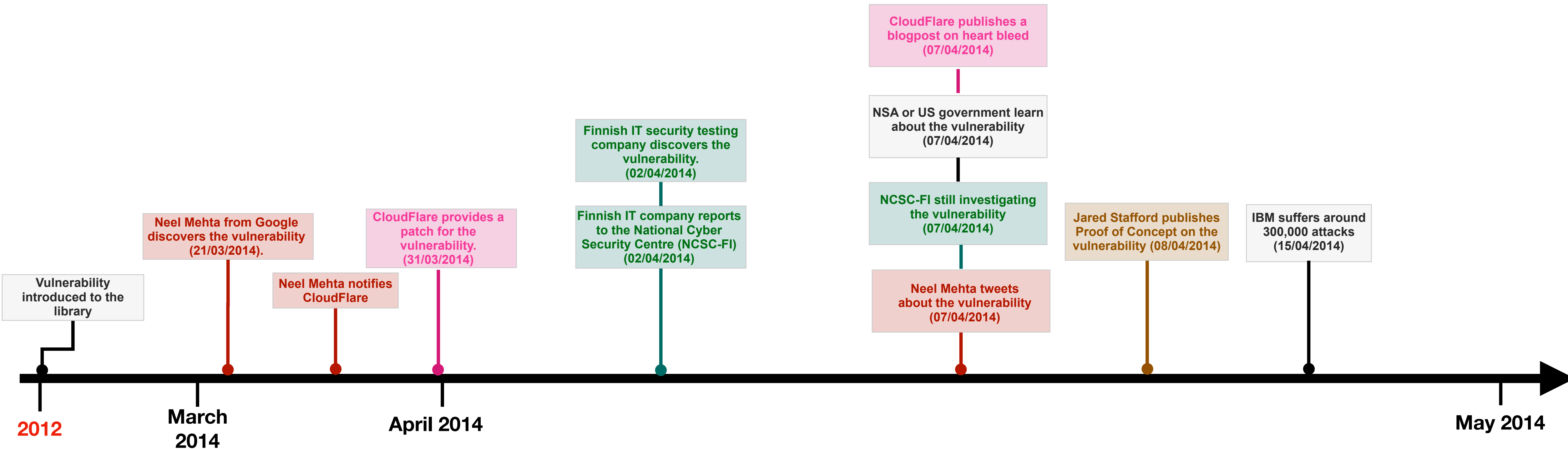
- OpenSSL cryptography library bug
- Date discovered: 1 April 2014
- Existed since 2012
- Take advantage of the heartbeat process. (Victim bleeds sensitive info to the attacker)
- Exposes contents of the memory buffer



VULNERABILITY RESEARCH

Vulnerability Disclosure Case study: Heartbleed (CVE-2014-0160)

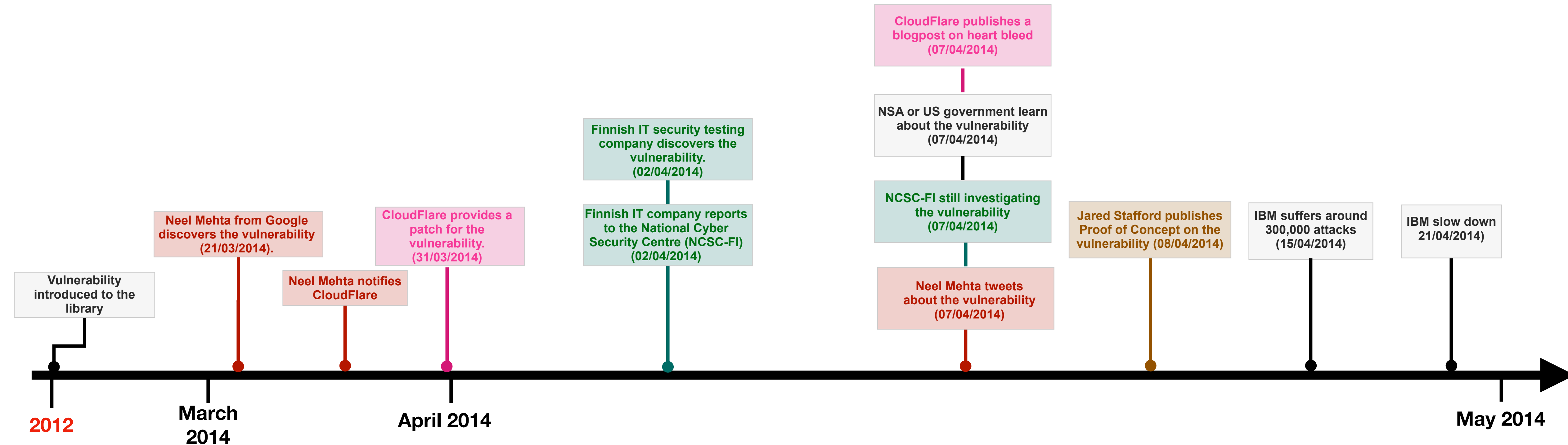
- OpenSSL cryptography library bug
- Date discovered: 1 April 2014
- Existed since 2012
- Take advantage of the heartbeat process. (Victim bleeds sensitive info to the attacker)
- Exposes contents of the memory buffer



VULNERABILITY RESEARCH

Vulnerability Disclosure Case study: Heartbleed (CVE-2014-0160)

- OpenSSL cryptography library bug
- Date discovered: 1 April 2014
- Existed since 2012
- Take advantage of the heartbeat process. (Victim bleeds sensitive info to the attacker)
- Exposes contents of the memory buffer



VULNERABILITY RESEARCH

Vulnerability Disclosure Effectiveness

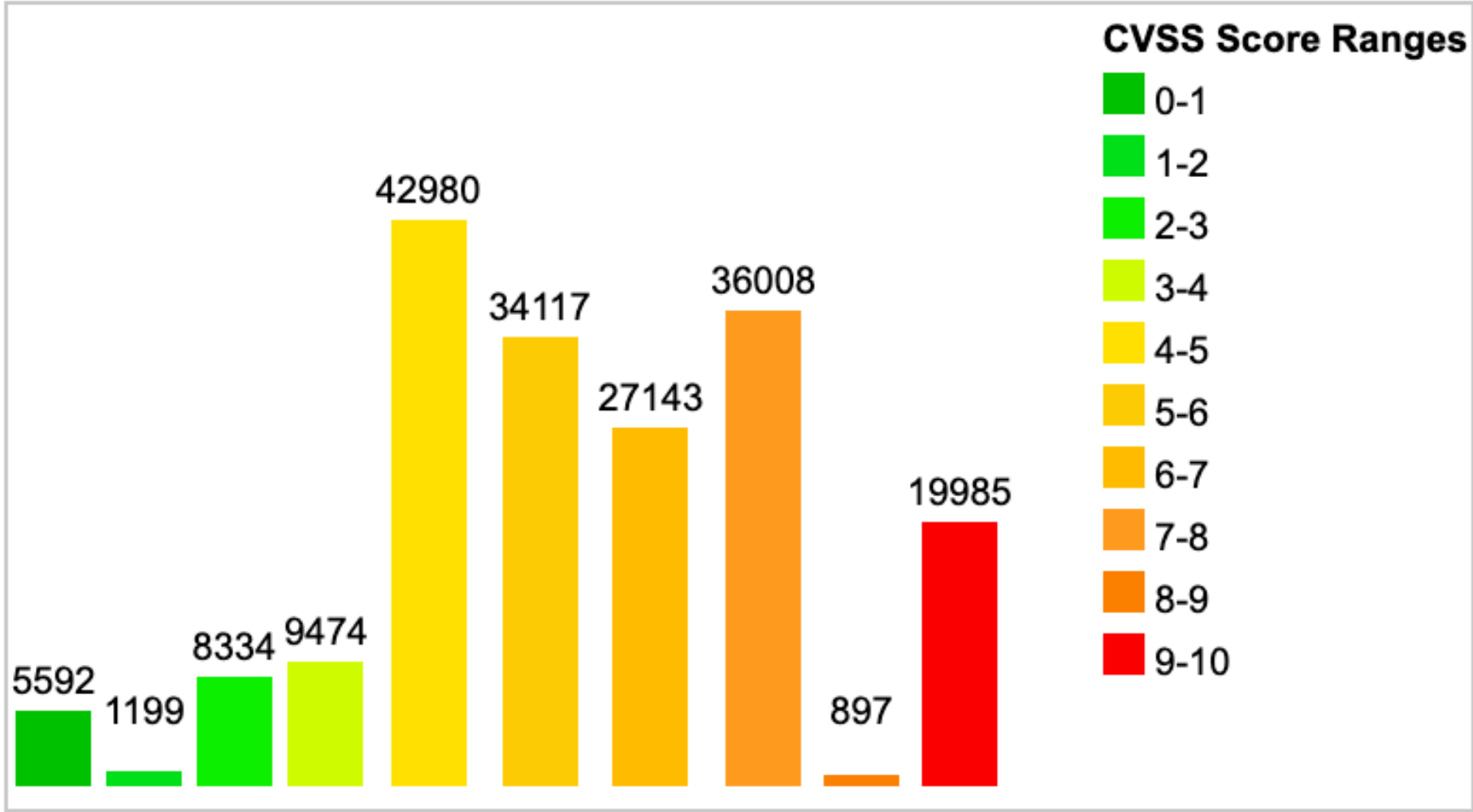
Current CVSS Score Distribution For All Vulnerabilities

Distribution of all vulnerabilities by CVSS Scores

CVSS Score	Number Of Vulnerabilities	Percentage
0-1	5592	3.00
1-2	1199	0.60
2-3	8334	4.50
3-4	9474	5.10
4-5	42980	23.10
5-6	34117	18.40
6-7	27143	14.60
7-8	36008	19.40
8-9	897	0.50
9-10	19985	10.80
Total	185729	

Weighted Average CVSS Score: **6.3**

Vulnerability Distribution By CVSS Scores



VULNERABILITY RESEARCH

How researchers should respond to finding a vulnerability?

- After discovering vulnerability the researcher should determine its potential impact
- The researcher should develop a detailed report with supporting evidence
- The researcher should give the vendor time to investigate the issue and advice on full disclosure timeline
- The researcher should make a full disclosure when a fix or patch has been found or time for full disclosure has elapsed



VULNERABILITY RESEARCH

How researchers should respond to finding a vulnerability?

- After discovering vulnerability the researcher should determine its potential impact
- The researcher should develop a detailed report with supporting evidence
- The researcher should give the vendor time to investigate the issue and advice on full disclosure timeline
- The researcher should make a full disclosure when a fix or patch has been found or time for full disclosure has elapsed

OWASP suggests researchers should:

- Ensure that any testing is legal and authorised.
- Respect the privacy of others.
- Make reasonable efforts to contact the security team of the organisation.
- Provide sufficient details to allow the vulnerabilities to be verified and reproduced.
- Not demand payment or rewards for reporting vulnerabilities outside of an established bug bounty program.



VULNERABILITY RESEARCH

How vendors should respond to vulnerability disclosure?

- Identify a rapid-response team to attend to the issue
- Create protocols for the team to follow
- Define priority levels and corresponding responses
- Set up a framework for determining priority levels
- Create clear procedures for responding to each level



VULNERABILITY RESEARCH

How vendors should respond to vulnerability disclosure?

- Identify a rapid-response team to attend to the issue
- Create protocols for the team to follow
- Define priority levels and corresponding responses
- Set up a framework for determining priority levels
- Create clear procedures for responding to each level

OWASP suggest organisations should:

- Provide a clear method for researchers to securely report vulnerabilities.
- Clearly establish the scope and terms of any bug bounty programs.
- Respond to reports in a reasonable timeline.
- Communicate openly with researchers.
- Not threaten legal action against researchers.
- Request CVEs where appropriate.
- Publish clear security advisories and changelogs.
- Offer rewards and credit.



Further Reading

Listen to this podcast: <https://www.cybok.org/events/software-security-with-frank-piessens>

<https://cwe.mitre.org>

<https://www.cve.org>

<https://nvd.nist.gov> <https://owasp.org/Top10/>



ETHICS

Ethics

What are ethics?

- *Ethics are a structure of standards, values, and practices that influence how people lead their lives.*
- *Not law*

Computer ethics

are a structure of standards, values, and practices that influence how people should process and consume computing technology and its related disciplines without damaging or violating the moral values and beliefs of any individual, organisation or entity.

Why are ethics important?

They ensure we:

- contribute to the wellbeing of the society acknowledging that all people are stakeholders in computing.
- build fair technology that does not to discriminate
- respect users' privacy and honour confidentiality.
- engage users in a respectable and safe manner
- respect other people's ideas and artefacts

Why do we need ethics for security practitioners?

- Security researchers are put in ***position of trust***
- Security jobs and roles are usually ***out of the public eye*** (scrutiny)
- Security researchers poses ***special knowledge and skills*** which are not common to everyone
- Security researchers may be in position of **power** with their clients, **power dynamics**.
- Security work or research could lead to public ***harm*** in some cases ***loss of life***.

What makes a good code?

- Detailed guidance on how to interpret and apply principles
- Addresses the relationship between entities
 - practitioner and client
 - Practitioner and society
 - (Balancing the relationships)
- Adoption and support by a well-defined community of practitioners

Examples

- ACM Code of ethics and Professional Conduct (2018)
- CREST code of Conduct

ACM Code of Ethics and Professional Conduct

GENERAL ETHICAL PRINCIPLES

A computing professional should...

- 1.1 Contribute to society and to human well-being, acknowledging that all people are stakeholders in computing.
- 1.2 Avoid harm.
- 1.3 Be honest and trustworthy.
- 1.4 Be fair and take action not to discriminate.
- 1.5 Respect the work required to produce new ideas, inventions, creative works, and computing artifacts.
- 1.6 Respect privacy.
- 1.7 Honour confidentiality.

Case study



James Davis

Apr 22, 2021 · 13 min read · [Listen](#)



Ethical conduct in cybersecurity research

What happened?

Researchers at the University of Minnesota conducted a research project titled *On the Feasibility of Stealthily Introducing Vulnerabilities in Open-Source Software via Hypocrite Commits*.

2018

UMN bug-fix research on Linux kernel starts, and roughly 400 bug-fix patches are contributed over the next two years, mainly centered around specific research papers

August 2020

"Hypocrite Commits" patches from UMN researchers sent to kernel developers under false identities.

November 2020

(1) "Hypocrite Commits" paper is published + accepted by IEEE Symposium on Security and Privacy

(2) Sarah Jamie Lewis calls attention to paper's ethics

- Is the threat model of hypocrite commits correct?
- Was this really a "safe" proof-of-concept?
- (When) are these methods for academic research sound?
- Should these methods be applied on cybersecurity?
- Should there be "no-go" ethical boundaries for safety-critical projects, such as the linux kernel?

Further Reading

<https://www.nytimes.com/2018/04/04/us/politics/cambridge-analytica-scandal-fallout.html>

<https://www.theguardian.com/technology/2019/mar/17/the-cambridge-analytica-scandal-changed-the-world-but-it-didnt-change-facebook>

Predicting whether people will lie online: <https://dl.acm.org/doi/pdf/10.1145/3411764.3445625>

Hypocrite commits paper disclosure: <https://www-users.cse.umn.edu/~kjl/papers/full-disclosure.pdf>

Hypocrite commits full paper: <https://linuxreviews.org/images/d/d9/OpenSourceInsecurity.pdf>

Privacy and Human Rights

Privacy and Human Rights

Privacy as a human right

“No one shall be subjected to arbitrary interference with his privacy, family, home or correspondence, nor to attacks upon his honour and reputation” - Article 12, UN Declaration of Universal Human Rights.

Other articulations

- *Right to be let alone*
- *Preventing personal information accessible to other entities without knowledge and consent*

Privacy and Human Rights

Privacy is political.

Privacy is a political right.

Political systems require privacy to function.

We, therefore, need to build technologies accordingly.

- *Privacy is a natural right that allows personal autonomy, while ensuring your democratic freedoms of association and expression.*

Privacy and Human Rights

Why do we study privacy?

- To understand what it means to individuals and society. *Remember* it is right and is contextual.
- Ensure that legal frameworks that underpin our democracies support privacy as a right.

Privacy and Human Rights

Why do we study privacy?

- Surveillance/Dataveillance
 - Chilling effects.
- Censorship
 - But free speech is a right... a political right.
 - Free media is integral component of a new, developing, or established democracy.
- Influencing people's decision making and behaviour

Privacy and Human Rights

Users' Privacy

Users are normally expected to manage their data or online privacy but most can't.

- Jargon language
- Complex systems
- Hidden or lack of mechanisms
- Dark patterns
- Too much work
- Lack of knowledge
- Misplaced mental models
- ...

Privacy and Human Rights

User Privacy Theories

Privacy calculus - Individual's intention to disclose personal information is based on risk-benefit analysis.

Privacy paradox - The discrepancy between an individuals' intentions to protect their privacy and how they actually behave in the online marketplace.

Privacy and Human Rights

Building to support the right to privacy

Privacy as confidentiality

Privacy as Control

Privacy as Transparency

Privacy and Human Rights

Building to support the right to privacy

Privacy as Transparency

Goal: *“informing the user about what data has been or can be collected, how it is processed and for what purpose.”*

Privacy and Human Rights

Building to support the right to privacy

Privacy as Transparency

***Goal:** “informing the user about what data has been or can be collected, how it is processed and for what purpose.”*

Transparency includes...

- Being open and clear about what data is collected
- The purpose for collecting that data
- Who is collecting the data and who will have access to the data
- The period the data will be stored (Retention period)
- When and how the data will be deleted

Privacy and Human Rights

Building to support the right to privacy

Privacy as Transparency

Goal: “informing the user about what data has been or can be collected, how it is processed and for what purpose.”

Transparency includes...

- Being open and clear about what data is collected
- The purpose for collecting that data
- Who is collecting the data and who will have access to the data
- The period the data will be stored (Retention period)
- When and how the data will be deleted

Examples

- Privacy policies
- Transparency reports
- Pop-up notices
- Privacy labels

Privacy and Human Rights

Building to support the right to privacy

Privacy as Control

***Goal:** “provide the user with means (mechanisms) to decide what information they will expose.”*

Privacy and Human Rights

Building to support the right to privacy

Privacy as Control

Goal: “provide the user with means (mechanisms) to decide what information they will expose.”

Mechanisms to control ...

- What data to share or can be collected
- What data can be processed
- Who can access the data
- Deletion or how data can be deleted

Privacy and Human Rights

Building to support the right to privacy

Privacy as Control

Goal: “provide the user with means (mechanisms) to decide what information they will expose.”

Mechanisms to control ...

- What data to share or can be collected
- What data can be processed
- Who can access the data
- Deletion or how data can be deleted

Examples

- Consent forms
- Privacy settings

Privacy and Human Rights

Building to support the right to privacy

Privacy as Confidentiality

Goal: “Hide data or information from adversary or unauthorised personnel”

Privacy and Human Rights

Building to support the right to privacy

Privacy as Confidentiality

Goal: “Hide data or information from adversary or unauthorised personnel”

Hide data when ...

- It is in transit (moving from one place to another)
- It is being processed
- It is at rest

Privacy and Human Rights

Building to support the right to privacy

Privacy as Confidentiality

Goal: “Hide data or information from adversary or unauthorised personnel”

Hide data when ...

- It is in transit (moving from one place to another)
- It is being processed
- It is at rest

Example

- Encryption
- Obfuscation
- Anonymisation

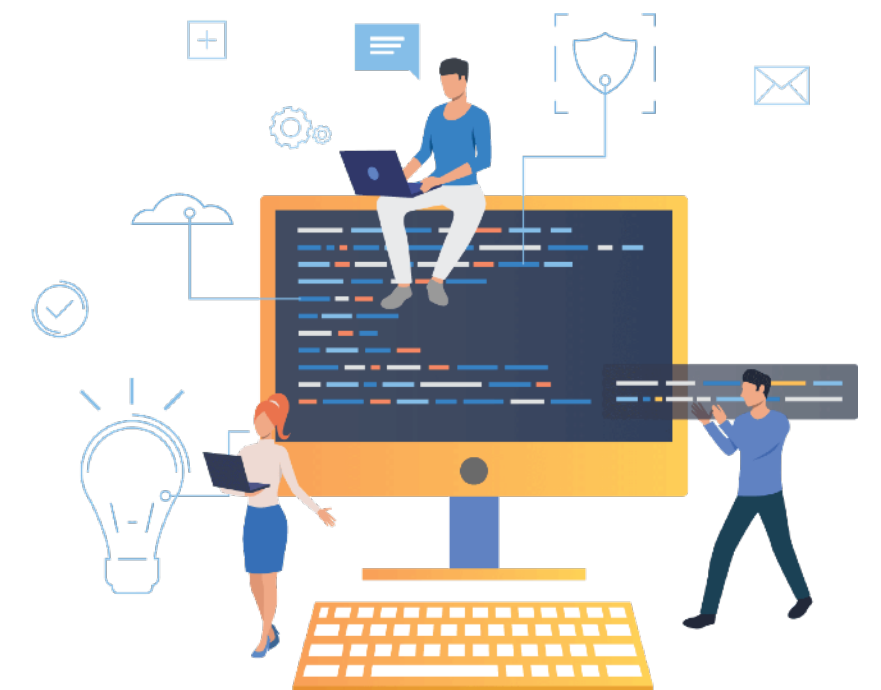
Privacy and Human Rights

Developers and User Privacy

Developers are normally excluded when it comes to issues of **user privacy**, in fact, they are usually **blamed** for **privacy violations**.

Misconceptions about developers

- Developers know everything and they know what is needed.
- Privacy is a regulatory problem, not a concept that developers should consider.
- Developers can easily interpret privacy regulations.
- Privacy mechanism are easy to implement.
- Users have the same privacy needs.
- Developers value privacy.
- Complying with privacy requirements and regulation is easy.



Privacy and Human Rights

Developers and User Privacy

Developers are normally excluded when it comes to issues of **user privacy**, in fact, they are usually **blamed** for **privacy violations**.

Challenges around implementing privacy

- Interpretation of regulations: Most developers do not understand the requirements of regulations.
- Implementation of regulations: It is not a straightforward process to implement privacy.
- Multi jurisdictional constraints (e.g., GDPR, CCPA are region specific): Developers need to consider a lot of regulations to ensure privacy.
- Unusable APIs and Frameworks: Privacy APIs and Frameworks are not easily available and not usable in most cases.
- Unusable tools: Most tools designed or created to implement privacy are unusable.
- **Skills and qualifications**: Most developers do not have the skills and knowledge about security and privacy.
- Misplaced Mental models: Developers understand privacy different and sometimes have misconceptions about what it means and its requirements.
- Shifting responsibilities: There is a confusion over who should ensure privacy compliance, developers or regulators



Further Reading

- ***Bugs in our pockets: The risks of client-side scanning*** <https://arxiv.org/pdf/2110.07450.pdf>
- ***CyBOK: Privacy and Online rights*** https://www.cybok.org/media/downloads/Privacy_Online_Rights_v1.0.2.pdf
-



Group Work

In August 2021, Apple proposed the first production Client-Side Scanning system, which had the potential to be deployed at global scale and installed in more than a billion Apple devices. Apple's proposal was primarily intended to detect CSAM using an on-device detection component that works with Apple servers using cryptographic protocols. Apple designed the scanning components to operate on photos stored in the Camera Roll (the device photo library) only when the "iCloud Photos" cloud synchronisation service is turned on.

In your groups, research about this proposal and prepare a short presentation answering the following questions:

- **what was the proposal about?**
- **What problem was Apple trying to solve?**
- **Whose power is increased by this proposal? Power to do what?**
- **Whose power is decreased in this proposal? Power to do what?**
- **Do you think client-side scanning poses an unacceptable threat to privacy? Why or why not?**

